



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



CISA Adds One Known Exploited Vulnerability to Catalog

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-12
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | CISA Adds One Known Exploited Vulnerability to Catalog - CVE / Vulnerability Threat Intelligence Report

Published: 2026-06-12 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

CISA Adds One Known Exploited Vulnerability to Catalog

1. Executive Summary

CISA added CVE-2026-35273, an Oracle PeopleSoft Enterprise PeopleTools missing-authentication vulnerability, to the Known Exploited Vulnerabilities (KEV) Catalog on 2026-06-12 based on evidence of active exploitation. Oracle's out-of-band security alert describes the issue as remotely exploitable without authentication, affecting PeopleTools 8.61 and 8.62 in the Updates Environment Management component. Public NVD/OpenCVE-style enrichment and Oracle's verbose advisory text rate the issue `CVSS 3.1 9.8 / CRITICAL` with network attack vector, low attack complexity, no required privileges, no user interaction, and high confidentiality, integrity, and availability impact.

For defenders, this is not a routine patch-cycle vulnerability. Multiple public reports, including Mandiant/Google Threat Intelligence Group coverage summarized in search results and downstream Rapid7 reporting, describe exploitation before or around Oracle's 2026-06-10 advisory window, with activity attributed to UNC6240 / ShinyHunters and observed against higher-education PeopleSoft infrastructure between 2026-05-27 and 2026-06-09. Those claims increase urgency, but they should be treated as campaign-context reporting rather than a complete list of affected victims or tradecraft.

Lost Boys Cyber assesses this vulnerability as critical for any organization operating PeopleSoft Enterprise PeopleTools 8.61 or 8.62, especially where PeopleSoft web tiers, Integration Broker, or Environment Management interfaces are reachable from the internet or semi-trusted partner networks. The immediate defensive priority is to apply Oracle's security alert guidance, remove public exposure to PeopleTools administrative and environment-management surfaces, hunt for unauthenticated access to suspicious PeopleSoft endpoints, and perform compromise assessment before considering remediation complete.

2. Intelligence Requirement

This report answers the following intelligence requirement: what should security and IT teams do after CISA added CVE-2026-35273 to KEV, which PeopleSoft deployments are most exposed, what exploitation context is publicly supportable, and which detection, hunting, and remediation actions should be prioritized now?

Question	Assessment
What changed?	CISA added CVE-2026-35273 to KEV on 2026-06-12, confirming enough evidence of active exploitation to require prioritized remediation by covered federal agencies and to justify urgent action by non-federal defenders.
What is vulnerable?	Oracle PeopleSoft Enterprise PeopleTools, component: Updates Environment Management; supported affected versions 8.61 and 8.62.
What is the weakness?	Missing authentication for a critical function (`CWE-306`) reachable over HTTP.
What is the likely impact?	Oracle and NVD-style summaries describe unauthenticated network compromise of PeopleTools, with public reporting characterizing the exploit chain as unauthenticated SSRF-to-RCE / remote code execution and full application takeover risk.
Who is at highest risk?	Internet-facing or partner-accessible PeopleSoft deployments, especially higher education, public sector, HR/finance, and other environments where PeopleSoft stores sensitive identity, employee, student, payroll, or benefits data.
What is the main uncertainty?	Public reporting identifies active exploitation and actor/campaign context, but reliable victim counts, exploit payload details, and stable infrastructure IOCs remain incomplete from sources

	reviewed for this draft.
What should defenders do first?	Patch per Oracle guidance, restrict PeopleSoft administrative and Environment Management exposure, preserve logs, and investigate for suspicious unauthenticated endpoint access before and after patching.

3. Source Review and Confidence

Source	Contribution	Confidence
CISA alert and KEV catalog entry	Confirms KEV addition, active-exploitation basis, required-action framing, and BOD 26-04 risk-prioritization context.	High
Oracle Security Alert Advisory - CVE-2026-35273	Canonical vendor remediation source; confirms PeopleTools product scope and unauthenticated remote exploitability.	High
Oracle verbose advisory / NVD / OpenCVE-style records	Provide affected versions 8.61 and 8.62, component name, CVSS vector `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`, and CWE mapping.	High
Google Cloud / Mandiant / GTIG reporting surfaced in search results	Describes active exploitation against PeopleSoft application infrastructure, UNC6240 / ShinyHunters attribution, higher-education targeting, and observed activity window.	Medium-High
Rapid7 coverage surfaced in search results	Corroborates unauthenticated SSRF-to-RCE framing, Oracle out-of-band advisory context, and Mandiant-confirmed zero-day exploitation.	Medium-High
Third-party security summaries	Provide additional operational framing around PeopleSoft exposure and PSEMHUB/Environment Management risk, but vary in specificity and should not replace Oracle or CISA guidance.	Medium

Confidence is high that CVE-2026-35273 is actively exploited, critical severity, remotely exploitable without authentication, and affects supported PeopleTools versions 8.61 and 8.62. Confidence is medium-high on public campaign context because several reputable sources summarize Mandiant/GTIG findings, but the report does not rely on unverified victim counts or unsourced exploit mechanics as fact.

Analytic assumptions used in this report are explicit: endpoint names such as PSEMHUB and Environment Management Hub are treated as high-priority review surfaces because public reporting repeatedly links the vulnerability to PeopleTools Environment Management exposure. Organizations should validate exact local URL patterns, servlet mappings, reverse-proxy paths, and logging fields before converting the provided queries into production alerts.

4.1 Vulnerability metadata

Field	Value
CVE	`CVE-2026-35273`
Vendor / product	Oracle PeopleSoft Enterprise PeopleTools

Component	Updates Environment Management / PeopleTools Environment Management surface
Weakness	`CWE-306 Missing Authentication for Critical Function`
Affected supported versions	PeopleTools 8.61 and 8.62
Public severity	`CVSS 3.1 9.8 / CRITICAL`
CVSS vector	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`
Exploitability	Remotely exploitable without authentication over HTTP/network access
Known exploitation	CISA KEV addition on 2026-06-12; public reporting describes zero-day exploitation before Oracle's alert
Primary impact	Unauthorized compromise of PeopleTools with potential remote code execution, data access, and application takeover implications
Primary remediation	Apply Oracle Security Alert CVE-2026-35273 patches and mitigations; restrict exposed PeopleSoft management surfaces; investigate for compromise

4.2 Defensive findings

Finding	Defensive implication	Priority
CVE-2026-35273 is in CISA KEV	Treat the vulnerability as actively exploited, not theoretical; remediation should be expedited and paired with compromise assessment.	Critical
The flaw is unauthenticated and network reachable	Exposed PeopleSoft HTTP surfaces can be abused without stolen credentials, reducing the usefulness of identity-only controls.	Critical
PeopleTools 8.61 and 8.62 are affected	Asset teams should not assume current supported versions are safe; exact PeopleTools version inventory is required.	Critical
PeopleSoft often stores sensitive HR, finance, identity, student, or benefits data	Exploitation can create material data-theft and extortion risk, not just application downtime.	High
Public reporting links exploitation to ShinyHunters / UNC6240 and higher education	Higher education and data-rich PeopleSoft operators should prioritize retrospective investigation for late-May through mid-June 2026 activity.	High
Stable public IOC coverage is limited	Defenders should focus on behavior, endpoint access, process execution, web logs, and anomalous PeopleSoft telemetry rather than waiting for IP/domain blocklists.	High

4.3 Exposure profile

Exposure pattern	Why it matters	Priority
Internet-facing PeopleSoft web tier or reverse proxy	An unauthenticated network flaw can be reached directly by opportunistic scanners or targeted actors.	Immediate
Exposed Environment Management / PSEMHUB-like endpoints	Public reporting repeatedly associates exploitation with Environment Management surfaces and unauthenticated RCE pathways.	Immediate
PeopleSoft hosting HR, student, finance, payroll, benefits, or identity data	Successful exploitation can support extortion, data theft, credential harvesting, and operational disruption.	High
Partner/VPN-only PeopleSoft access	Semi-trusted access still matters if broad partner, student, vendor, or unmanaged endpoints can reach PeopleSoft.	High
Patched PeopleTools with restricted management access and reviewed logs	Residual risk is lower, but historical compromise assessment remains necessary because exploitation preceded broad awareness.	Reduced

4.4 MITRE ATT&CK mapping

ATT&CK ID	Technique	Rationale
T1190	Exploit Public-Facing Application	Best-fit initial-access mapping when exposed PeopleSoft HTTP services are exploited without authentication.
T1059	Command and Scripting Interpreter	Applies if RCE is used to launch OS commands, scripts, or Java process children from the PeopleSoft application tier.
T1105	Ingress Tool Transfer	Applies if post-exploitation stages download web shells, tooling, or scripts to the PeopleSoft host.
T1005	Data from Local System	PeopleSoft application servers may expose sensitive configuration files, logs, attachments, or local data after compromise.
T1213	Data from Information Repositories	PeopleSoft frequently stores institutional HR, financial, student, or benefits records attractive to extortion actors.
T1078	Valid Accounts	Applies if exploitation enables credential theft, session material capture, or creation/use of PeopleSoft or OS accounts.
T1486	Data Encrypted for Impact	Conditional mapping for ransomware/extortion follow-on activity; not inherent to the CVE itself.

5. Threat Context

CVE-2026-35273 sits at the intersection of high-value enterprise applications and unauthenticated internet-reachable attack surface. PeopleSoft deployments commonly support HR, finance, student information, payroll, procurement, and benefits workflows. In many organizations the application tier is treated as business-critical infrastructure, reachable by broad user populations and protected by perimeter access controls that may not account for unauthenticated management endpoints or legacy servlet exposure.

CISA's KEV action changes the risk conversation. The vulnerability meets KEV criteria that require a CVE ID, evidence of exploitation, and clear remediation guidance. Under BOD 26-04, Federal Civilian Executive Branch agencies are required to prioritize remediation of high-risk KEV vulnerabilities on publicly exposed assets that can grant total control after exploitation and to perform compromise checks when required. Non-federal organizations should treat this as strong evidence that normal monthly patch timing is inadequate.

Public campaign reporting further increases urgency. Google Cloud / Mandiant / GTIG summaries surfaced in search results describe exploitation between 2026-05-27 and 2026-06-09 targeting Oracle PeopleSoft application infrastructure, attributed to UNC6240 / ShinyHunters, with a focus on higher education. Rapid7 reporting similarly summarizes the issue as a critical unauthenticated SSRF-to-RCE vulnerability in PeopleTools 8.61 and 8.62 and notes Mandiant-confirmed zero-day exploitation. Lost Boys Cyber did not independently validate every claimed victim or exploit detail, but the convergence of CISA KEV, Oracle's emergency alert, and reputable threat-intelligence reporting warrants immediate enterprise action.

Representative attack paths defenders should consider:

Scenario	Description	Defensive meaning
Direct public exploitation	Actor reaches an exposed PeopleSoft endpoint over HTTP/S and triggers the missing-authentication flaw without valid credentials.	Inventory public exposure and investigate all unauthenticated access to PeopleTools management or environment endpoints.
Data-theft and extortion path	Actor uses application compromise to access PeopleSoft records, export sensitive tables, or pivot to connected systems.	Treat patching as necessary but insufficient; review database, application, and file-access telemetry.
Web-tier post-exploitation	Actor obtains code execution in the PeopleSoft web/application tier and spawns commands or downloads tools.	Hunt for suspicious Java/WebLogic/Tuxedo child processes, new files, and outbound connections.
Partner or campus-network abuse	Actor reaches PeopleSoft from a semi-trusted network segment not considered public but broadly accessible.	Apply the same controls to VPN, student, vendor, and partner exposure as internet exposure.
Retrospective zero-day window	Exploitation occurred before Oracle's alert and CISA's KEV entry.	Preserve and analyze logs back to at least 2026-05-27; do not limit review to post-advisory dates.

6. Detection and Hunting

Detection strategy should combine exposure discovery, web/application telemetry, endpoint behavior on PeopleSoft servers, and retrospective compromise assessment. No source reviewed for this report provided a complete stable IOC set. The most durable signals are therefore suspicious access to PeopleTools Environment Management surfaces, PeopleSoft application-tier process behavior inconsistent with normal Java/WebLogic/Tuxedo operations, unexpected file creation under web/application directories, and sensitive-data access patterns after suspicious HTTP requests.

6.1 Detection coverage summary

Signal	Telemetry source	Analytic goal	Coverage caveat
--------	------------------	---------------	-----------------

PeopleTools 8.61 or 8.62 inventory	CMDB, vulnerability scanner, package/config inventory, PeopleSoft admin records	Identify assets requiring Oracle security-alert remediation.	Some scanners may identify the application but not the PeopleTools patch level.
Access to Environment Management / PSEMHUB-like paths	Reverse proxy, WAF, load balancer, web server, WebLogic, PeopleSoft logs	Surface likely exploit probing and high-risk management-surface exposure.	Exact URL paths and servlet mappings vary by deployment.
Unauthenticated HTTP POSTs or unusual methods to PeopleSoft admin paths	WAF/proxy/app logs	Identify exploitation attempts that do not follow normal authenticated user workflows.	Session and authentication fields must be mapped locally.
Suspicious child processes from Java/WebLogic/PeopleSoft services	EDR, Sysmon, Linux auditd, process accounting	Detect post-exploitation command execution.	RCE payloads may be memory-resident or use allowed admin utilities.
New web-accessible files, JSPs, scripts, archives, or staging files	File integrity monitoring, EDR, webroot scans	Identify web shells, dropped tools, or data staging.	Legitimate PeopleSoft updates can create files; correlate with change windows.
Large or unusual PeopleSoft data exports	Database audit, application audit logs, DLP, proxy egress	Detect data theft and extortion preparation.	PeopleSoft reporting jobs can be noisy; tune by user, time, and volume.

6.2 Sigma - suspicious PeopleSoft Environment Management endpoint access

```

title: Suspicious Access to PeopleSoft Environment Management Endpoint
id: f07e4832-a940-4fb3-b7e5-42dfc7738b71
status: experimental
description: Detects suspicious HTTP access to PeopleSoft Environment Management or PSEMHUB-like paths
that should be rare and tightly restricted. Adapt field names and approved source IPs to local proxy,
WAF, or application log schemas.
author: Lost Boys Cyber
date: 2026-06-15
references:
- https://www.cisa.gov/news-events/alerts/2026/06/12/cisa-adds-one-known-exploited-vulnerability-
catalog
- https://www.oracle.com/security-alerts/alert-cve-2026-35273.html
- https://cloud.google.com/blog/topics/threat-intelligence/shinyhunters-targets-education-sector-
oracle-exploit
logsource:
  category: webserver
detection:
  selection_path:
    cs-uri-stem|contains:
      - '/PSEMHUB'
      - '/psp/'
      - '/psc/'
      - 'EnvironmentManagement'
      - 'Environment%20Management'
  selection_method:
    cs-method:
      - 'POST'
      - 'PUT'
      - 'GET'
  filter_known_admin_sources:
    c-ip:
      - '10.0.0.0/8'
      - '172.16.0.0/12'
      - '192.168.0.0/16'
  condition: selection_path and selection_method and not filter_known_admin_sources
falsepositives:

```


- Legitimate PeopleSoft administrator activity from unmodeled jump hosts
- Health checks or monitoring probes that include PeopleSoft management paths

level: high

tags:

- attack.t1190

6.3 KQL - PeopleSoft web access hunt for Environment Management exposure

```
let lookback = 30d;
let PeopleSoftPathTerms = dynamic(['/PSEMHub', '/psp/', '/psc/', 'EnvironmentManagement',
'Environment%20Management']);
AppRequests
| where TimeGenerated > ago(lookback)
| extend UrlDecoded = url_decode(tostring(Url))
| where UrlDecoded has_any (PeopleSoftPathTerms)
| extend Method = tostring(Properties['Method']), User = tostring(Properties['User']), ClientIP =
tostring(ClientIP)
| project TimeGenerated, AppRoleName, ClientIP, Method, ResultCode, DurationMs, Success, User,
UrlDecoded
| order by TimeGenerated desc
```

6.4 KQL - suspicious child processes from PeopleSoft or Java application tier

```
let lookback = 30d;
DeviceProcessEvents
| where Timestamp > ago(lookback)
| where InitiatingProcessFileName in~ ('java.exe', 'java', 'w3wp.exe', 'httpd', 'nginx', 'tuxedo.exe')
or InitiatingProcessCommandLine has_any ('weblogic', 'peoplesoft', 'psft', 'tuxedo', 'PIA')
| where FileName in~
('cmd.exe', 'powershell.exe', 'pwsh.exe', 'wscript.exe', 'cscript.exe', 'bash', 'sh', 'curl', 'wget', 'certutil.
exe', 'bitsadmin.exe', 'python.exe', 'perl.exe', 'nc', 'ncat')
or ProcessCommandLine has_any ('/bin/sh', '/bin/bash', 'Invoke-WebRequest', 'IEX', 'curl', 'wget
', 'certutil -urlcache', '/tmp/', '/var/tmp/')
| project Timestamp, DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine, FileName,
ProcessCommandLine, AccountName, ReportId
| order by Timestamp desc
```

6.5 SPL - proxy/WAF review for PeopleSoft endpoint probing

```
(index=proxy OR index=waf OR index=web)
( uri_path="*PSEMHub*" OR uri_path="*/psp/*" OR uri_path="*/psc/*" OR
uri_path="*EnvironmentManagement*" OR uri="*PSEMHub*" OR uri="*EnvironmentManagement*" )
| eval src=coalesce(src_ip, client_ip, c_ip), method=coalesce(http_method, cs_method, method),
status=coalesce(status, sc_status, http_status)
| stats count min(_time) as first_seen max(_time) as last_seen values(method) as methods values(status)
as statuses values(user_agent) as user_agents by src, host, uri_path
| convert ctime(first_seen) ctime(last_seen)
| sort - count
```

6.6 SPL - endpoint process hunt on PeopleSoft servers

```
(index=edr OR index=sysmon OR index=osquery)
(parent_process_name IN ("java.exe", "java", "w3wp.exe", "httpd", "nginx", "tuxedo.exe") OR
parent_process="*weblogic*" OR parent_process="*peoplesoft*" OR parent_process="*PIA*")
(process_name IN
("cmd.exe", "powershell.exe", "pwsh.exe", "bash", "sh", "curl", "wget", "certutil.exe", "bitsadmin.exe", "python
.exe", "perl.exe", "nc", "ncat") OR process="*/tmp/*" OR process="*/var/tmp/*")
| table _time host user parent_process_name parent_process process_name process dest_ip
| sort - _time
```

6.7 Hunt hypotheses

Hypothesis	What to prove or disprove
PeopleSoft Environment Management surfaces were reachable from the internet or broad partner networks before patching	Review firewall, reverse-proxy, WAF, and external attack-surface inventory for PeopleSoft endpoint exposure.
Exploitation occurred during the pre-disclosure window	Search logs from at least 2026-05-27 through current date for

	unauthenticated access to PeopleSoft management paths and anomalous HTTP POSTs.
Application-tier code execution followed suspicious HTTP requests	Correlate PeopleSoft web requests with process creation, file writes, and outbound connections on the same host within short time windows.
Data theft or staging occurred after initial access	Review PeopleSoft audit logs, database queries, report exports, compressed archives, and outbound transfers for unusual volume or timing.
Credentials or session material were harvested	Audit new accounts, password resets, elevated PeopleSoft roles, service-account use, and authentication from unusual IPs after suspicious events.

7. Recommendations

Priority	Owner	Recommendation	Rationale
Critical	PeopleSoft / ERP owners	Apply Oracle Security Alert CVE-2026-35273 patches or vendor-approved mitigations for PeopleTools 8.61 and 8.62 immediately.	The issue is critical, unauthenticated, remotely exploitable, and KEV-listed.
Critical	Network / platform owners	Remove internet exposure to PeopleTools Environment Management, PSEMHUB-like, administrative, and diagnostic surfaces; require VPN/jump-host access and source restrictions.	Reduces exploit reachability even before every node is confirmed patched.
Critical	Incident response	Preserve and review web, WAF, load-balancer, application, OS, EDR, and database logs back to at least 2026-05-27.	Public reporting indicates exploitation occurred before Oracle's advisory window.
High	Detection engineering	Deploy adapted detections for suspicious PeopleSoft endpoint access, unusual Java/WebLogic child processes, new web-accessible files, and anomalous data exports.	Behavioral detections are more durable than incomplete IOC sets.
High	Vulnerability management	Validate actual PeopleTools patch level; do not rely only on generic Oracle application inventory or scanner plugin names.	Supported affected versions include 8.61 and 8.62; patch state may not be obvious from asset names.
High	Identity / ERP administrators	Review PeopleSoft users, roles, service accounts, integrations, and recent privilege changes after any suspicious access.	Application compromise can lead to persistent account or role misuse.
High	Database / data owners	Identify sensitive PeopleSoft	PeopleSoft data sensitivity

		tables and exports most likely to support extortion; monitor for unusual report generation or bulk access.	changes incident impact and notification obligations.
Medium	Security architecture	Segment PeopleSoft tiers, restrict outbound egress from application servers, and ensure administrative endpoints are not published through general reverse proxies.	Limits post-exploitation movement, tool download, and data exfiltration.
Medium	Executive / risk owners	Treat unpatched exposed PeopleSoft as a material business risk and track remediation through exception governance.	KEV-listed, actively exploited enterprise-application RCEs need leadership-level visibility.

Recommended immediate workflow:

1. Identify every PeopleSoft Enterprise PeopleTools instance, version, URL, reverse-proxy route, and environment-management endpoint.
2. Patch or mitigate per Oracle's CVE-2026-35273 security alert, prioritizing internet-facing and broad-access deployments.
3. Block direct public access to Environment Management / PSEMHUB-like paths and limit administration to known jump hosts.
4. Run retrospective hunts covering at least 2026-05-27 through the present and preserve logs before rotation.
5. If suspicious access is found, move from vulnerability remediation to incident response: isolate affected tiers, collect forensic images/logs, rotate relevant credentials, review PeopleSoft role changes, and assess data exposure.

8. References

- [R1] CISA alert, "CISA Adds One Known Exploited Vulnerability to Catalog": <https://www.cisa.gov/news-events/alerts/2026/06/12/cisa-adds-one-known-exploited-vulnerability-catalog>
- [R2] CISA Known Exploited Vulnerabilities Catalog: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [R3] Oracle Security Alert Advisory - CVE-2026-35273: <https://www.oracle.com/security-alerts/alert-cve-2026-35273.html>
- [R4] Oracle verbose risk matrix for CVE-2026-35273: <https://www.oracle.com/security-alerts/cve-2026-35273verbose.html>
- [R5] NVD entry for CVE-2026-35273: <https://nvd.nist.gov/vuln/detail/CVE-2026-35273>
- [R6] CVE record for CVE-2026-35273: <https://www.cve.org/CVERecord?id=CVE-2026-35273>
- [R7] Google Cloud / Mandiant / GTIG, "ShinyHunters Targets Education Sector with Oracle PeopleSoft Exploit": <https://cloud.google.com/blog/topics/threat-intelligence/shinyhunters-targets-education-sector-oracle-exploit>
- [R8] Rapid7, "Active Exploitation of Oracle PeopleSoft Zero-Day (CVE-2026-35273)": <https://www.rapid7.com/blog/post/etr-active-exploitation-of-oracle-peoplesoft-zero-day-cve-2026-35273/>
- [R9] OpenCVE entry for CVE-2026-35273: <https://app.opencve.io/cve/CVE-2026-35273>